面向软件归档的双层摘要相似试探与风险分流方法

作者姓名*

2026 年 5 月 9 日

摘要

软件**归档条目**（单文件、目录树或 ZIP 等压缩包）在 CI/CD 门禁、外包交付验收、开源合规筛查与内部制品风控等链路中高频流转；上述场景需要在**低算力、可审计、可配置**前提下，对**重复投递、表层改写（注释/空白/换行等噪声）及跨提交者可疑同质制品**进行**前置试探分流**，而非输出侵权或相似性终局结论。本文提出与具体垂类业务解耦的可部署范式：对归档完成**路径规整**后，构建**双层摘要**——**规范化摘要**（路径排序后串联、统一编码、对原始字节敏感）用于**精确去重**；**表层归一化内容摘要**（文本类条目经声明式表层归一化后按路径序串联再哈希，非文本条目采用原始字节摘要参与串联，规则**版本化备案**）用于**表层改写容忍**下的对齐与检索。在两枚表层归一化内容摘要之间定义**摘要距离分**：将摘要比特串的哈明距离经缩放与裁剪映射至 $[0, 100]$。该分值**不具有**语义或局部敏感指纹意义下的单调解释，**非**侵权或克隆相似度度量，**仅作**与阈值联动的**风险分流信号**。结合提交者关系与规则优先级，流水线输出可解释的风险等级与处置建议（如自动放行与人工复核），并保留字段级**审计留痕**。本文给出复杂度讨论、适用边界、集成架构与评估协议；实证将在脱敏数据集上独立完成并于定稿汇报。

关键词：软件制品；归档摘要；表层归一化；相似试探；风险分流；可审计风控

Abstract: Software *archive entries* (single files, directory trees, or compressed bundles such as ZIP) frequently flow through CI/CD gates, outsourced acceptance, open-source compliance screening, and internal artifact risk control. These settings demand *prescreening triage* under constrained compute with *auditability* and *policy configurability*, targeting duplicate submissions, superficially rewritten bundles (comments/whitespace/newline noise), and suspiciously homogeneous drops across submitters—without issuing final infringement or similarity adjudication. We present a deployable, domain-agnostic pipeline: after *path canonicalization*, we construct a *dual-layer digest*. A *canonical archive digest*

*作者单位与电子邮箱

concatenates sorted paths with unified encoding and raw-byte–sensitive material for *strict deduplication.* A *surface-normalized content digest* applies declarative text normalization (strip comments, collapse whitespace, unify newlines; non-text entries contribute fixed-length raw-byte digests in series), with rules *versioned for reproducibility*, concatenated in deterministic path order for *superficial rewrite tolerance.* Between two surface-normalized content digests we define a *digest distance score* by scaling and clipping the Hamming distance on digest bits to $[0, 100]$. This score is *not* a semantic metric nor a locality-sensitive fingerprint; it is *only* a triage signal coupled with thresholds. Together with submitter relationship and prioritized rules, the system yields interpretable risk bands and recommended actions (e.g., auto-pass vs. manual review) with field-level audit trails. We discuss complexity, applicability limits, deployment topology, and an evaluation protocol; empirical results will be reported on a de-identified dataset in the final version.
Key words: software artifact; archive digest; surface normalization; similarity probe; risk triage; auditable risk control

1 引言

1.1 问题背景与核心痛点

软件交付物在 CI/CD、制品库、外包验收、开源合规与内部托管等链路中常以**压缩包或快照归档**交换；路径编码异构、表层噪声普遍，风控或质检需在**低时延**下识别可疑同质投递。实践中的**三类核心痛点**为：（1）**整包哈希**对注释、空白、格式等**表层改写**易导致漏检；（2）代码相似检测（如 MOSS、AST/图方法或大模型路线）往往带来较高算力与时延成本，输出多为相似性报告，**可解释性与门禁决策**难以直接对齐；（3）工业场景更需要**风险分流与队列压缩**（放行/复核/升级），而非仅给出相似度排序。

1.2 现有方法的局限与本文缺口

整包哈希与制品库侧指纹擅长完全一致或字节级去重，但对表层变换敏感，难以支撑“归一化后一致”的试探。**SimHash 等局部敏感哈希**旨在使相近输入映射为相近指纹，哈明距离具有候选检索语义；本文采用的 SHA-256 具有**雪崩效应**，输入微小差异即可导致摘要比特大幅跳变，**不存在**“相似文档 → 相似摘要”的单调对应。**MOSS、Winnowing 等文本/令牌相似工具**面向教学抄袭等场景成熟[5,6]，典型输出为候选对与相似片段，与**归档条目集合 + 分流阈值 + 审计字段**的一体化门禁仍有落差。**AST/PDG 与大模型克隆检测**对语义克隆更敏感[3,4]；实证研究亦表明将大模型用于代码分析类任务仍存在能力与成本边界[2]，在线门禁中常受算力、时延、可审计参数化制约。综上，缺少一种**轻量、可审计、可配置**、面向**归档条目**的**双层摘要 + 摘要距离分 + 规则分流**一体化**试探范式**；本文填补该**工程落地**缺口。**本文不面向理论意义上的语**

义相似或克隆检测创新，而面向工程落地与风控范式：输出定位为**试探分流建议**，不替代司法鉴定、深度克隆检测或最终合规判定。

1.3 本文贡献

本文贡献可归纳为**四条可核验的学术与工程贡献**：

1. **双层摘要机制**：规范化摘要（精确去重）与表层归一化内容摘要（表层改写容忍）分工明确，路径排序后确定性串联，保证同一归档的可复现摘要。
2. **摘要距离分定义**：在固定长度摘要比特上定义哈明距离，经线性缩放、取整与裁剪得到 $[0, 100]$ 分值；阐明其与语义、局部敏感指纹的本质区别及**仅作分流阈值信号**的性质。
3. **提交者关系联动规则**：形式化风险模板，约束 $T_h > T_m$，优先级为跨提交者 > 高分段 > 中分段 > 低风险默认，抑制同提交者重复投递噪声。
4. **可审计流水线与评估协议**：从解析、摘要、规则到处置与留痕的步骤闭环；指标覆盖检测、运营与系统维度；消融与阈值敏感性可复现实验设计。

1.4 研究定位

本文定位为**工程落地风控方案**：在 API/CI 网关侧以**低算力试探**缩小人工复核面，强调**可解释、可审计、可配置、低时延**。方法**不主张**新的语义相似度理论，也**不提供**侵权或同质最终结论；与通用 clone/plagiarism 研究的分界在于对象（归档条目集合）、决策（风险分流而非相似度报告）、约束（审计与参数版本化）与输出（规则分支与复验字段）。

1.5 论文结构

第 2 节综述相关工作并与本文划界；第 3 节给出五步法、双层摘要、摘要距离分、规则模板、复杂度与适用边界；第 4 节描述部署架构与审计字段；第 5 节给出实验与消融协议；第 6 节在无实测数据前提下给出预期结论与分析框架；第 7 节总结并展望。

2 相关工作

2.1 软件制品去重

制品库与构建链路广泛使用文件级或整包哈希、内容寻址存储等进行去重与缓存一致性校验[1]；厂商制品门禁侧重恶意与策略合规。该类方法对**字节级一致**高效可靠，

但对**表层改写**易导致假阴性。**与本文对比**：本文保留**规范化摘要**承担强一致去重，并增设**表层归一化内容摘要**以拓展试探覆盖面，二者并行服务于门禁前置层。

2.2 代码相似检测

代码相似检测涵盖文本、令牌、树、图及混合路线[3]；Winnowing、MOSS 等广泛应用[5,6]；CCFinder、DECKARD 等支撑大规模克隆候选发现[8,9]。**与本文对比**：上述方法焦点常为**相似性度量或候选检索**；本文焦点为**归档条目级双层摘要**与**风险分流决策模板**，算力路径以轻量哈希与定长比特比较为主，可作为它们的**前置并联**环节而非替代。

2.3 局部敏感指纹

SimHash 等**局部敏感**哈希使相近文档映射为相近指纹，便于哈明阈值筛选近重复网页或文档[7]。**SimHash 与本文 SHA-256 的本质差异**：前者在设计上追求**局部敏感性**（相近输入 → 相近指纹）；SHA-256 为密码学摘要，强调**雪崩效应**与冲突阻力，**不具有**“输入相似度”与“摘要比特相似度”之间的**单调语义对应**。本文**摘要距离分**绑定于**表层归一化规则后的串联串**，**不得**解读为通用语义距离。

2.4 工业风控与人机协同

教育与工业工具普遍强调“算法提示相似，人工完成判断”[5,10]。制品门禁与合规流水线需要**可审计参数**（阈值、规则版本）、**低时延**与**队列运营指标**。制品库与 CI 产品常分别提供去重与策略门禁能力；**与本文对比**：本文将**归档解析、路径规整、双层摘要、摘要距离分检索、规则分流与审计留痕**纳入**同一可复现叙述**，便于在 API/CI 网关一站式落地与复盘。

2.5 研究差异总结

本文与相近研究可从四维度区分：**对象**——以多文件**归档条目**为单元，而非单文件片段比对为主；**决策**——输出**风险分流建议**（放行/复核等），而非相似度排行榜；**约束**——显式纳入提交者关系、阈值与规则**版本化**及审计字段；**输出**——返回命中标识、摘要距离分、关系判定、触发分支与处置依据，支持复核复验。整体上，本文为**轻量前置试探闸门**，可与 SimHash、AST、神经网络检测器等**并联**以增强召回或解释链。

3 方法

3.1 系统流程（五步）

系统在接收**软件归档制品**（或可映射为归档条目集合的上传单元）时，按下述**五步**执行：

1. **归档解析**：解压或遍历归档，枚举条目集合 $\{(p_i, c_i)\}$；不可解析的单文件输入退化为单条目特例。
2. **路径规整**：统一编码与路径分隔符语义，形成可排序的稳定路径键（实现侧应记录规则版本）。
3. **双层摘要计算**：对路径排序后按确定性顺序串联，分别计算**规范化摘要**与**表层归一化内容摘要**（见第 3.2 节）。
4. **摘要距离分与检索**：在历史池或候选集合上比对**表层归一化内容摘要**，计算**摘要距离分**；检索可由检测阈值 T_d 过滤候选。
5. **风险分级与审计留痕**：规则引擎综合摘要距离分、提交者关系与优先级输出风险等级与处置建议，并写入审计字段（见第 4 节）。

3.2 双层摘要构建

设上传归档 $A = \{(p_i, c_i)\}_{i=1}^{n}$，$p_i$ 为路径，c_i 为原始字节内容。对所有 p_i **字典序排序**后按下标顺序处理（**拼接顺序：路径排序后串联**，保证确定性）。

规范化摘要 H_{can}（路径规整后对**原始字节敏感**，用于**强一致去重**）：

$$H_{\text{can}} = \text{SHA256}\Big(\bigoplus_{i=1}^{n}\big(\text{norm}(p_i) \parallel \text{Base64}(c_i)\big)\Big), \tag{1}$$

其中 $\text{norm}(\cdot)$ 为路径规整映射，$\parallel$ 为字节连接，$\bigoplus$ 为按排序后顺序的字节串拼接（实现需在规则版本中固定分隔符与编码）。

表层归一化内容摘要 H_{surf}：对**文本类**条目将内容变换为 $\tilde{c}_i$（声明式**表层归一化**：去注释、压缩连续空白、统一换行等；编码统一到约定字符集）；对**非文本类**条目以 $\tilde{c}_i = \text{Hex}\big(\text{SHA256}(c_i)\big)$ 等形式嵌入**原始字节的固定长度摘要**参与串联（具体嵌入格式版本化备案）。则

$$H_{\text{surf}} = \text{SHA256}\Big(\bigoplus_{i=1}^{n}\big(\text{norm}(p_i) \parallel \tilde{c}_i\big)\Big). \tag{2}$$

文本/非文本判定由部署策略声明（扩展名、魔数或 MIME），并纳入规则版本。**规则版本化备案**用于复验：任一归一化步骤变更须递增版本号并留存文档。

3.3 摘要距离分

设两枚表层归一化内容摘要的十六进制串为 h_a, h_b（各对应 SHA-256 的 32 字节共 256 比特）。将其转为字节序列；若长度不一致，对较短一侧按实现约定补齐或按最大比特长度计算惩罚（须在规则版本中固定）。**哈明距离** $d_H(h_a, h_b)$ 定义为：两串对齐后逐字节异或，统计结果中二进制位为 1 的个数（等价于对称差比特总数）。

设摘要比特长度 L（对 SHA-256，L=256）。定义**裁剪函数** $\mathrm{clip}(x, a, b) = \min(\max(x, a), b)$；**取整函数** $\mathrm{round}(\cdot)$ 为四舍五入到整数。**摘要距离分**

$$S(h_a, h_b) = \mathrm{clip}\left(\mathrm{round}\left(100 \times \left(1 - \frac{d_H(h_a, h_b)}{L}\right)\right), 0, 100\right). \tag{3}$$

三条性质（须在使用中强制遵守）：

1. $S = 100$：当且仅当两枚表层归一化内容摘要比特完全一致（在既定串联与归一化版本下），对应**归一化层面完全一致**。
2. $S < 100$ **无语义单调性**：由于 SHA-256 的雪崩效应，S 与源代码“语义接近程度”**无**可用单调关系；不得将 S 解释为语义相似度。
3. **分流信号**：S **仅作**与 T_d, T_h, T_m 等阈值结合的**风险分流信号**，不构成侵权、克隆或合规终局判断。

3.4 风险评估规则（形式化模板）

设检测阈值 T_d 用于候选检索；高风险阈值 T_h、中风险阈值 T_m，且$T_h > T_m$。记 Cross 为跨提交者命中，$\neg$Cross 为同提交者命中。规则模板：

$$(S \geq T_h) \wedge \mathrm{Cross} \Rightarrow \text{高风险，人工复核;}$$
$$(S \geq T_h) \wedge \neg\mathrm{Cross} \Rightarrow \text{降级为中风险，人工复核;}$$
$$(T_m \leq S < T_h) \Rightarrow \text{中风险，人工复核;}$$
$$(S < T_m) \Rightarrow \text{低风险，策略定义自动放行或低优先级队列.}$$

优先级（冲突消解）：跨提交者条件 > 高分段条件 > 中分段条件 > 低风险默认。输出须包含触发分支编号或标识以便审计。

3.5 算法复杂度与工程意义

设归档总字节规模为 B，历史比对窗口规模为 M。解析与表层归一化为 $O(B)$，摘要计算为 $O(B)$；与窗口内候选的摘要距离分为定长比特运算，单次 $O(1)$，共 $O(M)$。总时间

$$T(B, M) = O(B + M). \tag{4}$$

工程意义：固定窗口 M 使比对开销**常数级上有界**，便于承诺线上 SLA；摘要长度固定使单次比较**低时延、可预测**。

3.6 适用边界

本文方法**仅适用于前置试探分流**：**不替代**司法鉴定、深度克隆检测或法务终判；**不构成**侵权或相似性结论；对深度重构、跨语言语义漂移、非文本主导工程等情形可能存在漏检或误判，应通过并联更强检测器或人工复核处置。

4 系统实现

4.1 部署架构

典型拓扑为：**API/CI 网关**接收归档 → **解析与路径规整**模块 → **双层摘要**计算组件 → **规则引擎**（阈值与提交者策略）→ **处置动作**（放行、阻塞、入复核队列）与**审计存储**。可与现有制品库、工单系统通过异步消息或回调集成；图示可与正文并排或在修订稿中补充架构图。

4.2 审计字段清单

建议每条判定至少持久化：**原始归档哈希**；**规范化摘要**与**表层归一化内容摘要**；**摘要距离分**；**风险等级**；**提交者关系判定**（同提交者/跨提交者）；**规则分支标识**与**规则/阈值版本号**；**时间戳**；**操作者或自动化主体标识**；可选**命中历史制品 ID**列表。

4.3 可解释返回内容

接口返回除等级外，应包含：**命中对象标识**、**摘要距离分**、**提交者关系**、**触发规则分支**、**处置依据引用**（策略文档版本或规则条目），以支持独立复验与复盘。

4.4 规则与阈值版本化

阈值 T_d, T_h, T_m、**表层归一化规则**与路径规整策略均应以版本号发布；审计记录绑定版本号，满足**可追溯**、**可审计**与合规复查需求。

5 实验设计

5.1 数据集协议

数据集须披露**来源**（开源快照、企业脱敏库或合成配对）、**标注准则**、**划分方式**。样本类型定义建议如下：**正样本**——同源归档经表层改写（注释/空白/换行等）；**负样本**——明确不同源；**难负样本**——同技术栈不同业务逻辑；**跨提交者样本**——不同账号或命名空间投递的高相似归档。划分按时间或提交批次切分，避免信息泄漏；标注可采用双人独立标注加仲裁。

5.2 基线设置

- **A**：仅整包或文件级 SHA-256（无归档条目双层摘要）。
- **B**：仅**规范化摘要**比对（无表层归一化内容串联）。
- **Ours**：完整方案：双层摘要 + 摘要距离分 + 提交者联动规则。

5.3 评价指标

- **检测指标**：Precision、Recall、F1、AUC（在既定标注口径下）。
- **运营指标**：复核命中率、无效复核量、端到端时延、队列长度 proxy。
- **系统指标**：吞吐（归档/秒）、CPU/内存增量开销。

5.4 阈值选择

两阶段：先在验证集上扫 T_d **保障召回**；再在业务成本函数下联合选取 T_h, T_m（满足 $T_h > T_m$），平衡复核人力与漏检风险。

5.5 消融实验（固定四组）

1. 移除**表层归一化**（仅保留规范化路径或其他弱化设定）。
2. 移除**同提交者降级**分支。
3. 移除或替换**历史窗口策略**（全量比对或极端窗口）。
4. **阈值敏感性**：扰动 T_d, T_h, T_m 观察检测与运营指标变化。

5.6 实验承诺

全部实证将在**脱敏数据集**上独立完成；最终版本将替换本节及以下分析中的实测数值，并补充伦理与数据治理说明。

6 结果与分析

本节在无最终实测数据条件下给出**预期结论与分析框架**；不填报具体数值。

6.1 主结果（预期）

预期 **Ours** 相对 **A** 在**表层改写**情形下具有更高召回；相对 **B**，表层归一化串联有助于在路径一致前提下对齐“注释/空白扰动”后的同质归档。**摘要距离分**与阈值共同决定进入复核的边界；分值**不得**按语义大小解读 ranking。

6.2 业务收益（预期）

预期在固定人力下提高**复核命中率**、降低**无效复核**比例；时延应保持在既定 SLA 内。定量结论待实测填入。

6.3 阈值分析

阈值降低通常提升进入复核的流量及与召回相关的指标，但增加人工负载；提高阈值则相反。由于 $S < 100$ 段**无语义单调性**，阈值应作为**运营参数**在验证集与回放数据中联合标定。

6.4 误差分析（典型三类）

1. **深度重构漏检**：逻辑等价的大规模重写使表层归一化后仍不收敛。
2. **多语言漂移**：跨语言或混编导致归一化层无法对齐。
3. **非文本误判**：二进制资源占比高或类型判定错误导致串联表征失真。

6.5 有效性威胁

包括**数据集偏差**、**标注口径**与**部署环境差异**。自动化输出仅为**试探分流建议**；最终合规或侵权判断由策略与有权主体作出；涉诉场景的证据链组织可参考司法鉴定与技术规范文献的精神[11,14,15]。

7 结论与展望

7.1 结论

针对引言所述**整包哈希表层漏检**、**重检测器不适配门禁**、**工业需分流而非单纯相似报告**三类痛点，本文给出**双层摘要**（规范化摘要精确去重 + 表层归一化内容摘要改写容忍）、**摘要距离分**（非语义、非局部敏感、仅分流信号）与**提交者关系联动**的规则化**风险分流**框架，并强调**可审计**、**可解释**、**可配置**、**低时延**的工程属性。方法定位为**试探分流建议**，不构成相似性或侵权判定。

7.2 展望（工程化三条）

1. **并联** SimHash/MinHash、AST 或令牌特征作多通道候选生成与解释增强。
2. **扩展** 许可证声明、第三方物料清单与二进制组件识别的预处理，减少非源码噪声干扰。
3. **多租户大规模验证与阈值自动优化**（在运营成本约束下回放标定）。

7.3 定位重申

本文为**轻量前置风控闸门**与**可审计流水线范式；不做法务或合规终判**，须与人工策略及必要时司法鉴定等手段衔接。

参考文献

[1] DI LUNA G A, et al. The Software Heritage Graph Dataset: Public Software Development Under One Roof[C]//Proceedings of the IEEE/ACM 42nd International Conference on Software Engineering (ICSE). New York: ACM, 2020: 138–148.

[2] FANG C, et al. Large Language Models for Code Analysis: Do LLMs Really Do Their Job?[C]//Proceedings of the 33rd USENIX Security Symposium (USENIX Security 24). Berkeley: USENIX Association, 2024: 5939–5956.

[3] Lee G, Kim J, Choi M S, et al. Review of Code Similarity and Plagiarism Detection Research Studies[J]. Applied Sciences, 2023, 13(20): 11358.

[4] Liu Z, et al. Towards Understanding the Capability of Large Language Models on Code Clone Detection: A Survey[EB/OL]. arXiv:2308.01191, 2023.

[5] Aiken A. Moss: A System for Detecting Software Similarity[EB/OL]. Stanford University. `https://theory.stanford.edu/~aiken/moss/`.

[6] SCHLEIMER S, WILKERSON D S, AIKEN A. Winnowing: Local Algorithms for Document Fingerprinting[C]//Proceedings of the 2003 ACM SIGMOD International Conference on Management of Data. New York: ACM, 2003: 76–85.

[7] HENZINGER M. Finding Near-Duplicate Web Pages: A Large-Scale Evaluation of Algorithms[C]//Proceedings of the 29th Annual International ACM SIGIR Conference on Research and Development in Information Retrieval. New York: ACM, 2006: 284–291.

[8] KAMIYA T, KUSUMOTO S, INOUE K. CCFinder: A Multilinguistic Token-Based Code Clone Detection System for Large Scale Source Code[J]. IEEE Transactions on Software Engineering, 2002, 28(7): 654–670.

[9] JIANG L, MISHERGHI G, SU Z, et al. DECKARD: Scalable and Accurate Tree-Based Detection of Code Clones[C]//Proceedings of the 29th International Conference on Software Engineering. IEEE Computer Society, 2007: 96–105.

[10] NOVAK M, JOY M, KERMEK D. Source-Code Similarity Detection and Detection Tools Used in Academia: A Systematic Review[J]. ACM Transactions on Computing Education, 2019, 19(3): Article 18.

[11] 中华人民共和国司法部. SF/T 0158—2023 软件相似性鉴定技术规范[S]. 北京: 中国标准出版社, 2023.

[12] 国家版权局. 计算机软件著作权登记办法[Z]. 2002.

[13] 国务院. 计算机软件保护条例（2013年修订）[Z]. 2013.

[14] 最高人民法院. 计算机软件著作权侵权案中源代码比对判断相关案例[EB/OL]. 2021.

[15] 最高人民法院知识产权法庭. 网络游戏计算机软件无代码比对时的实质性相似判断[EB/OL]. 2023.